

ZERO HEALTH CORP

Vulnerability Assessment Report

Prepared by: Onaopemipo Olugbemiro

Date: June 2025

Executive Summary

This vulnerability assessment was carried out on **Zero Health Corp** internal network following report of slow performance and repeated failed login attempt on the Zero Health Corp login admin portal. Through network discovery and in-depth investigation which reveal that one of the systems inside the network is outdated and running on an insecure software that could allow attackers to break in, steal sensitive data, or disrupt services, showing multiple security weaknesses. Which further increase the risk of exploitation. These findings represent a high to critical threat to the organization's internal infrastructure and sensitive health care data. Immediate actions are needed to update the affected systems, strengthen access control, and improve monitoring to prevent potential cyberattacks.

Scan Result

Method used: netdiscover (used to discover the hosts on the network)

- **Active Host Detected:** 26 host
- **Suspicious Host Identified:** 192.168.88.27(PCS systemtechnik GmbH)

Nmap Scan

There are 6 ports open that was found on 192.168.88.27:

- Port 22/tcp (SSH)
- Port 80/tcp (HTTP)
- Port 111/tcp (RPCBind)
- Port 139/tcp (NetBIOS-SSN)
- Port 443/tcp (SSL/HTTPS)
- 32768/tcp (FileNet-TMS)

```
File Actions Edit View Help
(kali@kali)-[~]
$ nmap 192.168.88.27
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-24 15:22 WAT
Nmap scan report for 192.168.88.27
Host is up (0.0014s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp    open  rpcbind
139/tcp    open  netbios-ssn
443/tcp    open  https
32768/tcp  open  filenet-tms
MAC Address: 08:00:27:41:D6:9E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Image shows nmap scans of open ports on the 192.168.88.27

Findings

Carried out a well detailed nmap scan and found open ports that had verifiable vulnerabilities that can be exploited on 192.168.88.27:

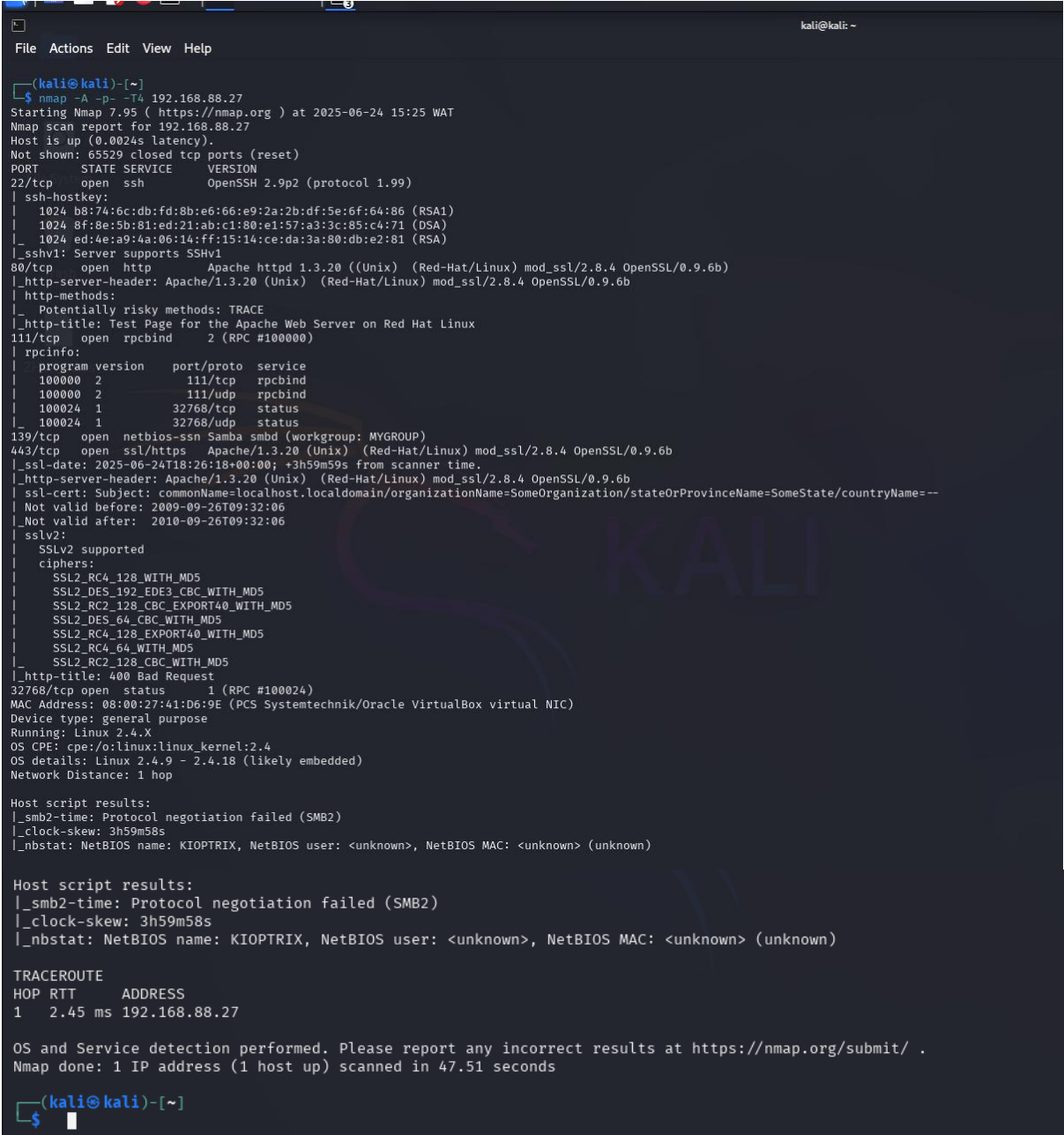


Image shows the verifiable vulnerabilities that can be exploited on 192.168.88.27

Our Findings

Our investigation identified outdated and misconfigured services exposing the system to critical and high-severity vulnerabilities:

- Apache HTTP Server: Directory traversal via malformed URL (CVE-2001-0912)
- OpenSSH: Buffer overflow in Kerberos token handling (BID 4560)
- Samba: Remote code execution vulnerability (CVE-2017-7494, known as ETERNALRED)
- rpc.lockd: Denial-of-service via malformed packets

Risk Assessment

Critical Severity Vulnerability

- Samba Remote Code Execution (CVE-2017-7494): Affects Samba versions 3.5.0 to 4.6.4, allowing unauthenticated users with write access to upload and execute shared libraries. This can result in full remote code execution on the host.
- OpenSSH Buffer Overflow (BID 4560): Versions prior to 2.9.9 are vulnerable to unauthenticated buffer overflow via malformed Kerberos tokens, potentially allowing arbitrary code execution.

High Severity Vulnerability

- Apache Directory Traversal (CVE-2001-0912): In Apache 1.3.x (Win32), a crafted URL with excessive slashes bypasses the index file check, exposing directory listings.

Medium Severity Vulnerability

- rpc.lockd Denial-of-Service: Malformed input to port 1024 terminates the rpc.lockd daemon, which does not release the port until the system is rebooted.

Low Severity Vulnerability

- Exposure of internal services like rpcbind and nlockmgr increases the surface for reconnaissance and potential exploit chains.

Port	Description	Impact	Vulnerabilities	CVE details	CVSS score	Mitigation
22/tcp (SSH)	A buffer overflow exists in OpenSSH due to improper handling of Kerberos 4 TGT/AFS tokens. It results from and unbounded strings copy, allowing stack overflow via malformed input. Versions prior to 2.9.9 are exploitable without authentication, while 2.9.9 and above require valid credentials.	Successful exploitation can lead to remote code execution, full system compromise, or DOS. Older versions pose higher risk due to unauthenticated access.	Unvalidated token input leads to stack-based buffer overflow via unsafe memory handling during Kerberos 4 processing.	CVE-2002-0575, affecting OpenSSH versions with Kerberos 4 support prior to 3.0.2. Public exploit is available.	High (7.5) – AV: N /AC: L/ Au:N/ I:C /A:C. Critical in pre-2.9.9versions high in later ones with authentication required.	Upgrade to OpenSSH 3.0.2 or later. Disable Kerberos 4 in sshd_config. Restrict SSH access and monitor logs.
80/tcp (HTTP)	A flaw in the Apache HTTP server 1.3x on windows allows attackers to bypass index files and view directory listings by appending multiple slashes to request. This is caused by improper handling of long paths when calling the stat function on windows.	An attacker may gain unauthorized access to directory contents, exposing sensitive files that should normally remain hidden. This could lead to information disclosure or aid further attacks.	The vulnerabilities stem from a path length handling issue in the Apache win32 port. When the path is too long, windows return an error, and Apache wrongly assumes the index file missing, enabling directory listing.	Identified as CVE-2000-0505, affecting Apache1.3x on windows when directory listing is enabled and no proper mitigation is in place.	Medium (5.0) - AV: N / AC: L / Au:N / C:P / I:N / A:N. the attacker require no authentication but only exposes without code execution.	Upgrade to new version of Apache. switch to Apache 2.x. disable directory listing by setting option IndexIgnore in configuration. Validate and sanitize requests to prevent excessive directory listings.
111/tcp (RPCBind)	This affect unix based system running rpcbind. The flaw allows a remote attacker to send specially crafted UDP packets that cause excessive memory allocation, potentially exhausting system resources and leading to DoS. The exploit takes advantage of the way rpcbind handles certain payloads in RPC calls.	Successful exploitation can cause the target system to become unresponsive due to memory exhaustion, effectively denying of service to legitimate users. It can also destabilize RPC-dependent services.	The Vulnerability lies in the failure of rpcbind to validate input size before memory allocation. Crafted RPC request causes uncontrolled memory allocation, leading to system wide resource exhaustion.	Identified as CVE 2017-8779, this issue affects rpcbind version using libtirpc, particularly on Linux and other Unix platforms. It is remote, unauthenticated DoS vulnerability.	High (7.5) AV: N / AC: L / Au:N / C:N / I:N / A:C. it's remotely exploitable without authentication and causes a complete loss of availability.	Update to a a patched version of rpcbind and ensure libtirpc is up to date. Restrict UDP access to port 111 via firewall. Monitor RPC service behavior. Apply rate-limiting where applicable.
139/tcp (NET BIOS-SSN)	Eternal red exploits a vulnerability in Samba version 3.5.0 to 4.5.10/4.4.14, where the server fails to properly validates shared libraries loaded from writeable network shares. An attacker with write access can upload a malicious shared object and cause	Successful exploitation results in remote code execution with root privileges, potentially allowing full system take over, persistence,	This flaw exists in Samba's dynamic module loading mechanism, which does not properly sanitize paths when handling shared libraries, allowing attackers to inject and execute arbitrary code.	CVE 2017-7494, it affects Samba 3.5.0 and later version up to 4.5.10. exploit is publicly available and widely used in the wild.	Critical (9.8) AV: N / AC: L / Au:N / C:C / I:C / A:C. It's remotely exploitable without authentication in some cases.	Update Samba to the latest patched version, and also restrict write access to network shares and segment your network to limit exposure.

	the sever to load it, executing arbitrary code as root.	lateral movement, or data exfiltration.				
443/tcp (SSL/HTTPS)	This is a buffer overflow in mod_sd, specifically when handling malfunction SSLv2 handshake messages. This allows an attacker to send specially crafted SSL packets to execute arbitrary code on the sever, typically leading to root shell.	The exploit enables remote code execution as the Apache user (commonly root on misconfigured systems), resulting in complete system compromise. It's a dangerous flaw due to its ease of use and availability of exploit code.	The root issue lies in insufficient bounds checking in mod_ssl's handling of SSLv2 handshake packets, allowing attackers to overflow memory buffers.	Tracked as CVE-2002-0082, this affects Apache with mod_ssl linked against OpenSSL versions prior to 0.9.6e, especially on Red Hat Linux and other Unix systems.	Critical (9.0) – AV: N / AC: L / Au:N / C:C / I:C / A:C. It allows remote, unauthenticated root access under certain configurations	Update OpenSSL to version 0.9.6e or higher and apply all mod_ssl patches. Disable SSLv2 support in Apache configuration. Use objdump -p to verify patched binaries. Monitor for unusual SSL traffic and restrict access where applicable.
32768/tcp (FileNet-TMS)	A vulnerability exists in the rpc.lockd daemon on Linux systems using NFS, where sending malformed or random data to the NFS lock manager port causes the daemon to crash. The socket it was bound to remains unusable until the system is rebooted, resulting in service disruption.	This leads to a denial of service on NFS-dependent services. Applications relying on file locking mechanisms may hang or fail, affecting system stability and data operations across the network.	The flaw is due to improper input validation in the NFS lockd daemon. When it crashes, the socket is not properly released, which prevents the service from restarting without a system reboot.	This issue was publicly reported but does not have a formal CVE assigned. It affects multiple Linux distributions with vulnerable nlockmgr (rpc.lockd) implementations.	Medium (5.0)– AV:N / AC:L / Au:N / C:N / I:N / A:P. It causes partial loss of availability but requires no authentication.	Apply kernel or NFS-related patches to fix rpc.lockd robustness. Restrict access to port 1024/tcp and update firewall rules. Where possible, monitor for unusual lock manager patterns and alert on unusual lock manager activity.

Security Recommendation

To enhance the security posture of the organization, it is crucial to adopt a proactive and layered defence strategy. Keeping all systems, services, and dependencies up to date is foundational; vulnerabilities like buffer overflows in OpenSSH or Samba exploits are often resolved in later releases. Service hardening should follow — unnecessary services must be disabled, and essential ones must be configured with strict security policies. Apache should not allow directory listings, Samba should not permit guest access or writable anonymous shares, and old protocols such as SSLv2 or NTLMv1 should be deprecated.

A strong perimeter should be enforced through network segmentation and firewalls. Internal services like NFS lockd or rpcbind should never be exposed to public networks. Where services must remain accessible, strict access controls based on IP whitelisting should be implemented. Beyond configuration, a principle of least privilege should be applied across all systems

ensuring services and users operate with only the permissions necessary for their function.

Regular vulnerability assessments and penetration tests should be conducted using automated tools and manual review. Detected issues should be tracked, prioritized, and remediated promptly. Log monitoring solutions (such as a SIEM) should be deployed to provide real-time alerts for suspicious activity, allowing timely response to potential breaches. Finally, administrators should be trained regularly on security best practices and incident handling procedures to build a culture of cybersecurity awareness within the organization.

Remediation

1. Patch and Upgrade

To eliminate known vulnerabilities, update Apache HTTP Server to a secure version that fixes the path enumeration flaw (CVE-2001-0912). Upgrade OpenSSH to a version later than 2.9.9 to patch the buffer overflow issue (BID 4560). For Samba, apply patches that resolve CVE-2017-7494 (ETERNALRED) to prevent remote code execution. Lastly, ensure the Linux kernel and associated NFS services are updated to address the denial-of-service vulnerability affecting rpc.lockd.

2. Reconfigure Insecure Services

Review and harden service configurations. On Apache, disable directory listing using the directive Options -Indexes and confirm index files (like index.html) are properly configured. In Samba, prevent unauthorized access by disabling guest permissions (guest ok = no and public = no) and restrict access to potentially dangerous named pipes. Make sure only authenticated and intended users can access shared resources.

3. Restrict Network Exposure

Limit access to vulnerable services by controlling inbound traffic to key ports such as 445, 139, 111, 1024, and 2049. Implement internal firewall rules or network segmentation to ensure only authorized hosts can communicate with these ports. Avoid exposing services like Samba, rpcbind, and NFS to the public internet.

4. Disable Legacy Protocols

Ensure deprecated and weak protocols like SSLv2 and SMBv1 are disabled. Enforce the use of modern encryption standards such as TLS 1.2 or higher. In both Apache and SSH configurations, restrict cipher suites to strong options only, preventing downgrade or cryptographic attacks.

5. Audit and Monitor

Enable detailed logging on all affected services, especially for authentication attempts, system crashes, and share access. Integrate logs into a centralized Security Information and Event Management (SIEM) tool to detect abnormal behavior early. Regularly review logs for signs of exploitation or misconfiguration.

6. System Clean up and Recovery

If any of the vulnerabilities have been exploited (e.g., causing rpc.lockd to crash), reboot the affected systems to release occupied ports and restore full service. Check for any suspicious dropped files, scripts, or binaries that may have been placed during exploitation, and remove them securely.

7. Validate Fixes

After completing remediation steps, conduct thorough validation. Perform fresh scans using tools like Nmap, Nessus, or OpenVAS to ensure the vulnerabilities are no longer present. If feasible, replicate the original attack scenarios in a test environment to confirm they have been fully mitigated.

8. Documentation and Training

Document all changes made, including patches applied, configurations changed, and services affected. Hold a debrief session with the IT team to review the incident and update security procedures. Provide training on secure service deployment and regular patch management to prevent recurrence.

References

- SecurityFocus BID 4560 - OpenSSH Buffer Overflow
- SecurityFocus BID 1284 - Apache Directory Listing
- CVE-2017-7494 - Samba Remote Code Execution
- rpc.lockd DoS Vulnerability

- Exploit Database: 21402 - OpenSSH Buffer Overflow

Security Recommendation